# ADOPCIÓN DE ESTRATEGIAS DE CIBERSEGURIDAD PARA LA PROTECCIÓN DE LA INFORMACIÓN

La cadena de suministro de software incluye el código propio, las librerías de terceros, el repositorio de código, el pipeline de integración/despliegue continuo (CI/CD) y la infraestructura donde finalmente corre la aplicación. Cuando una librería de terceros falla, es maliciosa o resulta incompatible, y el proceso de despliegue no cuenta con controles de verificación, el resultado es el colapso de la aplicación al llegar al usuario final: el servicio no inicia, queda caído o expone datos. A continuación se presenta la tabla de vulnerabilidades y la tabla de riesgo asociadas específicamente a este escenario, aplicando la metodología Probabilidad × Impacto vista en la formación (escala 1 a 5; 1-4 Bajo, 5-9 Medio, 10-15 Alto, 16-25 Crítico).

## 1. Tabla de Vulnerabilidades

| ID | Activo afectado | Vulnerabilidad identificada | Amenaza asociada | Prob. (1-5) | Impacto (1-5) | Nivel (P×I) | Control / Mitigación propuesta |
|---|---|---|---|---|---|---|---|
| **V-01** | Librería de terceros (dependencia externa) | Dependencias sin versión fija ni archivo de bloqueo (lockfile) | Actualización automática incompatible o maliciosa | 4 | 5 | **20 - CRÍTICO** | Fijar versiones exactas + lockfile + Dependabot |
| **V-02** | Pipeline CI/CD (build y despliegue) | Ausencia de análisis de composición de software (SCA/SAST) antes de publicar | Paso de librería vulnerable directo a producción | 5 | 4 | **20 - CRÍTICO** | Integrar escaneo SCA/SAST (Snyk, Trivy) como paso obligatorio |
| **V-03** | Infraestructura de despliegue (contenedores/nube) | No existe ambiente de staging previo a producción | El fallo de la librería solo se detecta cuando ya llegó al usuario final | 4 | 4 | **16 - CRÍTICO** | Flujo dev → staging → prod con puntos de control |
| **V-04** | Aplicación desplegada (frontend/backend) | No hay estrategia de reversión (rollback) automática | Indisponibilidad prolongada del servicio tras un despliegue fallido | 4 | 4 | **16 - CRÍTICO** | Estrategia Blue/Green con rollback automático |
| **V-05** | Registro de paquetes (npm / PyPI / Nexus) | Registro sin protección frente a dependency confusion / typosquatting | Instalación de un paquete público malicioso con nombre similar al interno | 3 | 5 | **15 - ALTO** | Registro privado con lista blanca (allowlist) de paquetes |

| ID | Activo afectado | Vulnerabilidad identificada | Amenaza asociada | Prob. (1-5) | Impacto (1-5) | Nivel (P×I) | Control / Mitigación propuesta |
|---|---|---|---|---|---|---|---|
| **V-06** | Artefactos de compilación (build) | Artefactos generados sin firma digital | Suplantación o inyección de código durante el proceso de build | 3 | 4 | **12 - ALTO** | Firmar artefactos (Cosign/Sigstore) y verificar antes de desplegar |
| **V-07** | Documentación técnica del despliegue | No existe SBOM (inventario de componentes de software) | Respuesta lenta ante el incidente por desconocer qué librería falló | 4 | 3 | **12 - ALTO** | Generar SBOM (formato CycloneDX) en cada compilación |
| **V-08** | Infraestructura de producción | Falta de monitoreo y verificaciones de salud (health-checks) post-despliegue | Detección tardía del colapso del servicio | 5 | 3 | **15 - ALTO** | Monitoreo con alertas automáticas (Prometheus/Grafana) |

## 2. Tabla de Riesgo

| ID | Vulnerabilidad de origen | Riesgo (qué puede ocurrir) | Consecuencia para el usuario final | Prob. | Imp. | P×I | Nivel | Control / Plan de mitigación | Responsable |
|---|---|---|---|---|---|---|---|---|---|
| **R-01** | V-01 | Colapso total del despliegue por librería incompatible | La aplicación queda fuera de servicio para todos los usuarios. | 4 | 5 | 20 | **CRÍTICO** | Pinning de versiones + staging + rollback automático | DevOps |
| **R-02** | V-02 | Explotación de una vulnerabilidad (CVE) conocida en producción | El atacante roba datos o ejecuta código a costa del usuario final. | 4 | 5 | 20 | **CRÍTICO** | SCA obligatorio en el pipeline + parcheo prioritario | Seguridad |
| **R-03** | V-03, V-04 | Despliegue directo a producción sin red de seguridad | El usuario recibe una aplicación caída o con errores (5xx). | 4 | 4 | 16 | **CRÍTICO** | Gates de calidad en staging + Blue/Green + rollback | DevOps |
| **R-04** | V-05 | Instalación de un paquete de terceros malicioso (typosquatting) | Se entrega al usuario una app con backdoor que compromete sus datos. | 3 | 5 | 15 | **ALTO** | Registro privado con allowlist + firma de paquetes | DevOps |

| ID | Vulnerabilidad de origen | Riesgo (qué puede ocurrir) | Consecuencia para el usuario final | Prob. | Imp. | P× I | Nivel | Control / Plan de mitigación | Responsable |
|---|---|---|---|---|---|---|---|---|---|
| **R-05** | V-08 | Detección tardía del colapso por falta de monitoreo | La falla se prolonga porque el equipo se entera por reclamos de usuarios. | 5 | 3 | 15 | **ALTO** | Observabilidad, alertas y guardias (on-call) | SRE |
| **R-06** | V-06 | Despliegue de un artefacto de build manipulado | El usuario final ejecuta una versión distinta a la auditada, de comportamiento incierto. | 3 | 4 | 12 | **ALTO** | Build reproducible + firma con Cosign | DevOps |
| **R-07** | V-07 | Respuesta lenta ante el incidente por falta de SBOM | El usuario permanece más tiempo afectado mientras se identifica la librería causante. | 4 | 3 | 12 | **ALTO** | SBOM (CycloneDX) por cada compilación + runbook | SRE |

***Conclusión:*** El mayor riesgo del caso (R-01 y R-02, nivel CRÍTICO) se origina en la falta de control de versiones sobre las librerías de terceros y en la ausencia de escaneo de vulnerabilidades (SCA/SAST) dentro del pipeline. Priorizar el fijado de versiones, la incorporación de SCA/SAST y un mecanismo de rollback automático reduce de forma directa la probabilidad de que la aplicación colapse al llegar al usuario final.

## MATRIZ DE RIESGOS — Colapso en el despliegue por cadena de suministro y librería de terceros

*Cómo leer (fácil): Probabilidad (1=muy raro, 5=casi seguro) × Impacto (1=menor, 5=catastrófico) = P×I. 1-4 BAJO (verde) · 5-9 MEDIO (amarillo) · 10-15 ALTO (naranja) · 16-25 CRÍTICO (rojo). Ordenada de mayor a menor riesgo.*

| ID Riesgo | Vuln. origen | Activo afectado | Riesgo (qué puede pasar) | Consecuencia para el usuario final | Prob. (1-5) | Impacto (1-5) | P×I | Nivel | Control / Plan de mitigación | Responsable | Estado |
|---|---|---|---|---|---|---|---|---|---|---|---|
| RSG-01 | VULN-01, VULN-02 | ACT-10, ACT-02 | Colapso total del despliegue: la app no inicia por librería incompatible | La aplicación queda fuera de servicio para todos los usuarios finales. | 4 | 5 | 20 | CRÍTICO | Pinning + staging + rollback | DevOps | Abierto |
| RSG-02 | VULN-02, VULN-03 | ACT-10, ACT-08 | Explotación de CVE en librería en producción (robo de datos / RCE) | Atacante ejecuta código o filtra datos de usuarios aprovechando la librería vulnerable. | 4 | 5 | 20 | CRÍTICO | SCA + parcheo <15 días + WAF | Seguridad | Abierto |
| RSG-05 | VULN-08, VULN-09 | ACT-07, ACT-10 | Indisponibilidad prolongada sin rollback | Caída de horas: pérdida económica, SLA penalizado y daño reputacional. | 4 | 4 | 16 | CRÍTICO | Blue/Green + rollback auto | DevOps | Abierto |
| RSG-03 | VULN-06 | ACT-05, ACT-04 | Instalación de paquete malicioso. | Se despliega código con backdoor que roba credenciales o mina datos. | 3 | 5 | 15 | ALTO | Registro privado + firma + SCA | DevOps | Abierto |
| RSG-04 | VULN-05 | ACT-09, ACT-03 | Compromiso del pipeline por secreto filtrado | Atacante publica versiones alteradas o borra artefactos, bloqueando releases. | 3 | 5 | 15 | ALTO | Vault + rotación + MFA | Seguridad | Abierto |
| RSG-08 | VULN-10 | ACT-07 | Detección tardía del fallo (sin monitoreo) | El colapso dura más porque nadie se entera hasta el reclamo masivo. | 5 | 3 | 15 | ALTO | Observabilidad + alertas + on-call | SRE | Abierto |
| RSG-06 | VULN-07 | ACT-03 | Cambio no autorizado en producción | Un merge sin revisión introduce la librería fallida o puerta trasera. | 3 | 4 | 12 | ALTO | Branch protection + revisión doble | Tech Lead | Abierto |
| RSG-07 | VULN-04 | ACT-04, ACT-06 | Artefacto manipulado (build no confiable) | Se despliega un binario distinto al auditado, con comportamiento desconocido. | 3 | 4 | 12 | ALTO | Build reproducible + Cosign | DevOps | Abierto |
| RSG-09 | VULN-11 | ACT-11 | Respuesta lenta al incidente por falta de SBOM | No se identifica la librería culpable; el MTTR pasa de minutos a días. | 4 | 3 | 12 | ALTO | SBOM CycloneDX + runbook | SRE | Abierto |
| RSG-10 | VULN-12 | ACT-07, ACT-08 | Corrupción de datos por mala configuración / migración fallida | El deploy a medias deja la BD inconsistente y requiere restauración de backup. | 3 | 4 | 12 | ALTO | Migraciones versionadas + backup probado | DBA / DevOps | Abierto |
| RSG-11 | VULN-08 | ACT-12 | Pérdida de confianza del usuario final y sanciones | Usuarios abandonan la plataforma; posibles multas por incumplimiento de disponibilidad. | 3 | 3 | 9 | MEDIO | Comunicación + SLA + postmortem | Product Owner | Abierto |

## MAPA DE CALOR 5×5 — Probabilidad (filas) ×

*Ubica cada riesgo por su P×I. Ejemplo: RSG-01 (4×5=20) va en fi*

| P ↓ / I → | I=1 | I=2 | I=3 |
|---|---|---|---|
| P=5 | 5 | 10 | 15<br>RSG-08=15 |
| P=4 | 4 | 8 | 12<br>RSG-09=12 |
| P=3 | 3 | 6 | 9<br>RSG-11=9 |
| P=2 | 2 | 4 | 6 |
| P=1 | 1 | 2 | 3 |

## Impacto (columnas)

*la P=4, columna I=5 (zona roja).*

| I=4 | I=5 |
|---|---|
| 20 | 25 |
| 16<br>RSG-05=16 | 20<br>RSG-01=20, RSG-02=20 |
| 12<br>RSG-06=12, RSG-07=12, RSG-10=12 | 15<br>RSG-03=15, RSG-04=15 |
| 8 | 10 |
| 4 | 5 |

## PL

*Ordenado por nivel de*

| Prioridad | ID Riesgo | Nivel |
|---|---|---|
| 1 | RSG-01, RSG-02, RSG-05 | CRÍTICO |
| 2 | RSG-03, RSG-04 | ALTO |
| 3 | RSG-06, RSG-07 | ALTO |
| 4 | RSG-08, RSG-09, RSG-10 | ALTO |
| 5 | RSG-11 | MEDIO |

## AN DE TRATAMIENTO PRIORIZADO — Qué hacer primero

*riesgo. Los CRÍTICOS van primero (0-7 días), luego ALTOS (<30 días) y MEDIOS (<90 días).*

| Acción inmediata | Plazo |
|---|---|
| Fijar versiones + activar SCA en pipeline + habilitar rollback automático y staging | 0-7 días |
| Migrar a registro privado con allowlist + guardar secretos en Vault y rotarlos + MFA | 7-15 días |
| Proteger ramas main + doble revisión + firmar artefactos con Cosign | 15-30 días |
| Monitoreo con alertas + SBOM CycloneDX por build + backups probados | 15-30 días |
| Plan de comunicación, postmortem y seguimiento de SLA | <90 días |

| Responsable |
| --- |
| DevOps + Seguridad |
| DevOps + Seguridad |
| Tech Lead + DevOps |
| SRE + DBA |
| Product Owner |

## CASO: Colapso en el despliegue por cadena de suministro y librería de terceros — ACTIVOS INVOLUCRADOS

*Hoja 1 de 3 · Inventario de todos los activos afectados. Criticidad: Crítica / Alta / Media. Fuente: análisis del caso.*

| ID | Activo | Tipo | Criticidad | Descripción / Por qué importa en este caso |
|---|---|---|---|---|
| ACT-01 | Código fuente de la aplicación | Software | **Crítica** | Repositorio Git (GitHub/GitLab). Contiene la lógica del negocio. Si se contamina, todo el despliegue falla. |
| ACT-02 | Librería de terceros (dependencia externa) | Software / Suministro | **Crítica** | Ej: librería npm / pip / log4j. El colapso se origina aquí: versión vulnerable, obsoleta o maliciosa. |
| ACT-03 | Repositorio de código (GitHub / GitLab) | Plataforma | **Alta** | Punto de entrada de la cadena. Requiere control de accesos, ramas protegidas y revisión de PR. |
| ACT-04 | Pipeline CI/CD (build + deploy) | Proceso | **Crítica** | Jenkins / GitHub Actions. Compila, prueba y despliega. Sin escaneo SCA/SAST deja pasar la librería fallida. |
| ACT-05 | Registro de paquetes / Artefactos (npm, PyPI, Nexus) | Plataforma | **Alta** | Origen de las dependencias. Riesgo de dependency confusion y typosquatting. |
| ACT-06 | Servidor de compilación / Runner | Infraestructura | **Alta** | Máquina que construye el artefacto. Si se compromete, inyecta código malicioso. |
| ACT-07 | Infraestructura de despliegue (Docker / K8s / Nube) | Infraestructura | **Crítica** | Donde corre la app en producción. El colapso aquí deja sin servicio al usuario final. |
| ACT-08 | Base de datos y datos de usuarios | Datos | **Crítica** | Integridad y disponibilidad. Una caída del deploy puede corromper migraciones o dejarla inaccesible. |
| ACT-09 | Credenciales y secretos (tokens, API keys) | Seguridad | **Crítica** | Permiten publicar/desplegar. Expuestos en código provocan toma de la cadena. |
| ACT-10 | Aplicación desplegada (frontend + backend / APIs) | Servicio | **Crítica** | Lo que ve el usuario final. Es donde se evidencia el colapso: errores 500, caída total. |
| ACT-11 | SBOM + Documentación de despliegue | Información | **Media** | Inventario de componentes y guía de rollback. Su ausencia impide diagnosticar qué librería falló. |
| ACT-12 | Equipo DevOps / Desarrolladores y Usuario final | Personas | **Alta** | Personas que operan y usan el sistema. Mala configuración o falta de capacitación amplifica el impacto. |

## MATRIZ DE VULNERABILIDADES — Cadena de suministro / Librería de terceros

*Hoja 2 de 3 · Cómo leer: Probabilidad x Impacto = Nivel. CRÍTICO = actuar ya · ALTO = plan <30 días · MEDIO = plan <90 días.*

| ID | Activo afectado | Vulnerabilidad | Descripción (qué pasa en este caso) | Amenaza asociada | Probabilidad (1-5) | Impacto (1-5) | Nivel de riesgo | Control / Mitigación propuesta |
|---|---|---|---|---|---|---|---|---|
| VULN-01 | ACT-02, ACT-05 | Dependencia sin versionado fijo (sin pinning / lockfile) | El package.json / requirements no fija versiones exactas. En el despliegue se descarga 'latest' y entra una versión incompatible que rompe la app. | Actualización automática maliciosa o ruptura de compatibilidad | Alta (4) | Crítico (5) | | Fijar versiones + lockfile + Dependabot |
| VULN-02 | ACT-02, ACT-11 | Librería de terceros obsoleta / sin parches | Librería con CVE conocido y sin actualizar por meses. Colapsa al desplegar porque el entorno nuevo ya no la soporta. | Explotación de CVE pública | Alta (4) | Alto (4) | ALTO | Política de actualización + SCA |
| VULN-03 | ACT-04 | Pipeline sin análisis de composición (SCA) ni SAST | El CI/CD compila y despliega sin escanear vulnerabilidades. La librería fallida pasa directo a producción. | Despliegue de componente vulnerable | Muy Alta (5) | Alto (4) | | Integrar Trivy / Snyk / Dependabot en pipeline |
| VULN-04 | ACT-04, ACT-06 | Artefactos sin firma digital (sin Cosign / Sigstore) | No se verifica la procedencia del build. No se puede asegurar que el artefacto desplegado sea el auditado. | Suplantación / inyección en el build | Media (3) | Alto (4) | ALTO | Firmar artefactos y verificar firma al desplegar |
| VULN-05 | ACT-03, ACT-09 | Secretos expuestos en el repositorio | Tokens de despliegue escritos en código o .env subido a Git. Permiten alterar el pipeline o el registro. | Toma de cuentas / sabotaje del deploy | Media (3) | Crítico (5) | | Vault + git-secrets + rotación |
| VULN-06 | ACT-05 | Registro sin protección contra Dependency Confusion / Typosquatting | El pipeline puede descargar un paquete público con el mismo nombre que uno interno malicioso. | Instalación de paquete malicioso | Media (3) | Crítico (5) | ALTO | Feed privado + scopes + allowlist |
| VULN-07 | ACT-03 | Ramas sin protección y sin revisión de código | Cualquiera puede hacer merge a main y cambiar la versión de la librería sin revisión. Mala configuración del repo. | Cambio no autorizado | Alta (4) | Medio (3) | **MEDIO** | Branch protection + 2 revisores + CODEOWNERS |
| VULN-08 | ACT-04, ACT-07 | Sin ambiente de staging / pruebas previas | Se despliega directo a producción. No se detecta que la librería rompe la app hasta que le llega al usuario final. | Fallo total en producción | Alta (4) | Alto (4) | ALTO | Pipeline: dev → staging → prod con gates |
| VULN-09 | ACT-07, ACT-10 | Despliegue sin estrategia de rollback automático | Si el deploy colapsa no hay forma de volver a la versión estable. El servicio queda caído horas. | Indisponibilidad prolongada | Alta (4) | Alto (4) | | Blue/Green + health-checks + rollback auto |
| VULN-10 | ACT-07, ACT-08 | Falta de monitoreo y health-checks post-despliegue | Sin alertas ni logs centralizados. El colapso se detecta por quejas de usuarios, no por el equipo. | Detección tardía | Muy Alta (5) | Medio (3) | ALTO | Prometheus + alertas + SLOs |
| VULN-11 | ACT-11 | Sin SBOM (inventario de componentes) | No se sabe qué versión de qué librería lleva cada despliegue. Imposible responder rápido al incidente. | Respuesta lenta al incidente | Alta (4) | Medio (3) | **MEDIO** | Generar SBOM (CycloneDX) por build |
| VULN-12 | ACT-12, ACT-07 | Mala configuración del despliegue (puertos, variables, permisos) | La 'mala posición/configuración': variables de entorno erradas y permisos excesivos hacen que la app no arranque tras el deploy. | Error humano / misconfiguration | Media (3) | Alto (4) | ALTO | IaC + checklist + least privilege |

## ESCALA DE VALORACIÓN Y RESUMEN EJECUTIVO

*Probabilidad e Impacto de 1 (muy bajo) a 5 (crítico). Nivel = Probabilidad × Impacto: 1-4 Bajo · 5-9 Medio · 10-15 Alto · 16-25 Crítico.*

| Rango | Clasificación | Significado | Plazo | Nº vulnerabilidades |
|---|---|---|---|---|
| 16 – 25 | CRÍTICO | Colapso del despliegue / servicio caído | Inmediato (0-7 días) | 2 |
| 10 – 15 | ALTO | Riesgo alto de fallo en producción | Corto plazo (<30 días) | 8 |
| 5 – 9 | MEDIO | Debilidad controlable con buenas prácticas | Mediano plazo (<90 días) | 2 |
| 1 – 4 | BAJO | Riesgo menor, monitorear | Monitoreo continuo | 0 |

**CONCLUSIÓN: el caso colapsa porque el pipeline no detecta la librería fallida (VULN-01 a VULN-03) y no hay red de seguridad (staging + rollback + monitoreo). Prioridad: fijar versiones, activar SCA/SAST y habilitar rollback automático.**